

Die Architektur der Unsicherheit: Eine tiefgreifende Analyse der Risiken in der Datensicherung und Archivierung

Autor: Mevluet Polat

Datum: 24. Feb 2026

Abstract

In der heutigen digitalen Ära stellen Daten das wertvollste immaterielle Gut eines Unternehmens dar. Doch mit der zunehmenden Abhängigkeit von digitalen Infrastrukturen steigen auch die Risiken für die Datenintegrität und -verfügbarkeit. Der vorliegende Artikel untersucht systematisch die von Mevluet Polat identifizierten Risikoarten in der Datensicherung und Archivierung. Dabei werden technische, menschliche, organisatorische und externe Faktoren beleuchtet. Ziel ist es, ein umfassendes Verständnis für die Komplexität moderner IT-Sicherungsprozesse zu vermitteln und aufzuzeigen, wie durch gezielte Prävention und klare Verantwortlichkeiten Geschäftsdaten nachhaltig geschützt werden können.

1. Einleitung

Die fortschreitende Digitalisierung hat dazu geführt, dass nahezu alle Geschäftsprozesse in Schweizer Unternehmen von der IT-Infrastruktur abhängen. Ob Buchhaltungsdaten, Kundendatenbanken oder geistiges Eigentum – der Verlust dieser Informationen kann existenzbedrohende Ausmasse annehmen. Mevluet Polat weist in seinen Ausführungen darauf hin, dass Unternehmen täglich einer Vielzahl von Gefahren ausgesetzt sind. Die Komplexität moderner, vernetzter Systeme führt dazu, dass Fehlerquellen nicht mehr isoliert betrachtet werden können, sondern als Teil eines hochdynamischen Ökosystems verstanden werden müssen.

Dieser Artikel strukturiert die Risiken gemäss der Polat-Methodik und untermauert die theoretischen Grundlagen mit anschaulichen Beispielen aus der Unternehmenspraxis.

2. Grundlagen der Datensicherungsrisiken

Die Datensicherung (Backup) und die Archivierung sind zwei unterschiedliche, wenn auch eng verwandte Disziplinen. Während das Backup der kurzfristigen Wiederherstellung nach einem Datenverlust dient, fokussiert die Archivierung auf die langfristige, revisionssichere Aufbewahrung. Die Risiken in diesem Bereich sind vielfältig.

2.1 Technische Grundlagen und Komplexität

Die Architektur moderner IT-Landschaften hat sich in den letzten Jahren fundamental gewandelt; sie sind keine monolithischen Blöcke mehr, die zentral gesteuert werden können. Heute bestehen Unternehmensstrukturen aus einem hochgradig heterogenen Mix aus Cloud-Instanzen (SaaS, PaaS, IaaS), On-Premise-Servern in lokalen Rechenzentren sowie einer Vielzahl mobiler Endgeräte. Diese fortschreitende Dezentralisierung und Vernetzung erhöht die Wahrscheinlichkeit von Fehlern bei der Datensicherung signifikant, da Daten nicht mehr an einem Ort verharren, sondern über verschiedene Schnittstellen (APIs) und Protokolle fließen.

Wenn ein Backup-Job über verschiedene Netzwerksegmente, unterschiedliche Provider und geografische Grenzen hinweg laufen muss, steigt die Anzahl der potenziellen Fehlerquellen – der sogenannten "Single Points of Failure" – exponentiell an. Ein Ausfall bei einem Identitätsprovider oder eine Fehlkonfiguration in einem VPN-Tunnel kann ausreichen, um den gesamten Sicherungsprozess zum Erliegen zu bringen. Zudem führt die Nutzung von "Schatten-IT" dazu, dass Daten in Diensten gespeichert werden, die von der zentralen IT-Sicherung gar nicht erfasst werden. Die Konsequenz dieser Komplexität ist eine erschwerte Überwachbarkeit, da die Abhängigkeiten zwischen den Systemen oft so dicht verwoben sind, dass ein kleiner Fehler in einem Subsystem kaskadenartige Ausfälle in der gesamten Sicherungskette nach sich ziehen kann.

Beispiel: Ein mittelständisches Unternehmen in Zürich nutzt eine hybride Cloud-Lösung. Die tägliche Sicherung der lokalen Datenbanken erfolgt automatisiert in ein Rechenzentrum in Genf. Aufgrund einer Fehlkonfiguration im Software-Defined Network (SDN) wird der Datenstrom während des Sicherungsvorgangs gedrosselt, was dazu führt, dass das Zeitfenster für die Sicherung überschritten wird und nur Fragmente übertragen werden. Ohne Monitoring bleibt dieser Fehler unentdeckt.

3. Technische Risiken: Die Fragilität der Infrastruktur

Technische Defekte sind oft unvorhersehbar und stellen eine der häufigsten Ursachen für permanenten Datenverlust dar. Sie resultieren aus dem physikalischen Verschleiss von Komponenten oder unvorhersehbaren Anomalien in der Infrastrukturumgebung.

3.1 Hardwaredefekte und Speichermedien

Mevluet Polat betont, dass Festplattenausfälle zu den kritischsten Faktoren gehören. Trotz moderner Redundanztechnologien wie RAID (Redundant Array of Independent Disks) bleibt ein erhebliches Restrisiko bestehen. Ein weit verbreiteter Irrtum ist die Annahme, ein RAID-System ersetze das Backup. In der Realität führt jedoch ein Defekt des RAID-Controllers oder das gleichzeitige Versagen zweier Festplatten in einem RAID-5-Verbund oft zum Totalverlust des gesamten logischen Volumens. Besonders kritisch ist die Phase des "Rebuilds" nach einem

Defekt: Die verbleibenden Festplatten werden unter maximale Last gesetzt, was die Wahrscheinlichkeit eines zweiten, fatalen Ausfalls drastisch erhöht.

- **Veraltete Medien und Bit-Rot:** Physische Speichermedien unterliegen einem schleichenden Verfallsprozess. Bänder (LTO), die über Jahre hinweg nicht unter optimalen klimatischen Bedingungen gelagert wurden, können beim ersten Einleseversuch nach langer Zeit reißen oder aufgrund magnetischer Entladung Lesefehler aufweisen. Ein ebenso gefährliches Phänomen ist der sogenannte "Bit-Rot" (stille Datenkorruption), bei dem einzelne Bits auf magnetischen oder optischen Medien ihre Ladung verlieren, ohne dass das Betriebssystem dies sofort bemerkt. Erst beim Versuch, das Archiv wiederherzustellen, erweist sich die Datei als beschädigt.
- **Hardware-Verschleiss bei Solid-State-Drives (SSDs):** SSDs basieren auf NAND-Flash-Speicher, der eine physikalisch begrenzte Anzahl an Schreibzyklen aufweist. In Backup-Umgebungen, die durch massive, tägliche Schreiboperationen gekennzeichnet sind, erreichen diese Laufwerke ihre "End-of-Life"-Schwelle oft deutlich schneller als in herkömmlichen Desktop-Anwendungen. Zudem besteht bei SSDs das Risiko des Datenverlusts durch Ladungsverlust, wenn sie über längere Zeiträume ohne Stromversorgung gelagert werden – ein kritischer Aspekt für die Langzeitarchivierung auf stromlosen Medien.
- **Minderwertige Komponenten:** Der Einsatz von Consumer-Hardware in professionellen Serverumgebungen erhöht die Fehlerquote massiv. Billige Speichermedien sind oft nicht für den 24/7-Betrieb ausgelegt und weisen eine höhere Fehlerrate bei der Fehlerkorrektur (ECC) auf, was die langfristige Datenintegrität gefährdet.

3.2 Netzwerkstörungen und Stromausfälle

Die Abhängigkeit von einer stabilen Infrastruktur ist die Achillesferse jeder Datensicherungsstrategie. Unerwartete Unterbrüche im Firmennetzwerk, sei es durch defekte Switches, überlastete Router oder fehlerhafte Routing-Tabellen, können laufende Sicherungsprozesse abrupt stoppen. Da viele Backup-Systeme transaktionsbasiert arbeiten, führen solche Abbrüche oft dazu, dass der gesamte Sicherungssatz verworfen werden muss oder, schlimmer noch, inkonsistente Datenfragmente im Zielsystem verbleiben.

- **Instabile Verbindungen in verteilten Systemen:** Besonders bei Off-Site-Backups (Sicherung an einem externen Standort) spielen Latenz und Jitter eine entscheidende Rolle. Selbst kurze "Micro-Outages" können dazu führen, dass die Synchronisation zwischen Quell- und Zielsystem die Integrität verliert. Dies ist besonders problematisch bei Echtzeit-Replikationen, wo ein Netzwerkfehler die Datenbanktransaktionen auf beiden Seiten asynchron werden lässt.
- **Gefahrenquelle Stromversorgung:** Ein plötzlicher Stromausfall während eines aktiven Schreibvorgangs ist eines der gefährlichsten Szenarien. Die Schreibköpfe herkömmlicher Festplatten können unter Umständen nicht mehr rechtzeitig in die Parkposition fahren, was zu einem "Head-Crash" führen kann. Bei modernen Servern können zudem die Daten

im volatilen Schreibcache verloren gehen, bevor sie auf das physische Medium geschrieben wurden, was das Dateisystem der Sicherungskopie korrumpiert (Dirty Shutdown).

- **Unzureichendes USV-Management:** Eine unterbrechungsfreie Stromversorgung (USV) allein bietet keinen absoluten Schutz. Wenn die USV-Akkus nicht regelmässig gewartet werden oder die Kapazität für die Last der angeschlossenen Systeme nicht mehr ausreicht, schaltet sich das System im Notfall dennoch hart ab.

Erweitertes Beispiel: Während einer kritischen nächtlichen Vollsicherung ereignet sich in einem Industriegebiet ein lokaler Stromausfall. Die USV des Hauptservers funktioniert einwandfrei und hält das System online. Jedoch wurde bei der Planung übersehen, dass die externe Storage-Unit, auf der das Backup-Image geschrieben wird, an einem separaten Stromkreis ohne USV-Absicherung hängt. In dem Moment, in dem die Storage-Unit den Dienst quittiert, versucht der Server weiterhin, Datenfragmente zu senden. Das Resultat ist ein beschädigter Datei-Header im Backup-Katalog des Servers, wodurch nicht nur das aktuelle Backup, sondern auch die Verknüpfung zu den vorangegangenen inkrementellen Sicherungen unbrauchbar wird. Das Unternehmen steht somit ohne funktionierende Wiederherstellungsbasis da.

4. Menschliche Risiken: Der Faktor "Layer 8"

In der Fachwelt wird die menschliche Komponente oft scherzhaft als "Layer 8" bezeichnet – die Schicht oberhalb des technischen OSI-Modells. Mevluet Polat weist jedoch mit Nachdruck darauf hin, dass dieser Faktor alles andere als ein Scherz ist. Während technische Defekte oft durch Redundanz abgefangen werden können, schlagen menschliche Fehler direkt in das Herz der Datensicherheit ein. Das Paradoxon liegt darin, dass Unternehmen Millionen in Cyber-Abwehr investieren, aber die Schulung derer vernachlässigen, die täglich die "Löschen"-Taste drücken oder Passwörter auf Post-its notieren. Menschliches Versagen ist nicht nur eine statistische Wahrscheinlichkeit, sondern eine konstante Bedrohung, die durch Stress, mangelndes Verständnis oder Bequemlichkeit befeuert wird.

4.1 Fehlbedienung, Unwissenheit und kognitive Überlastung

Versehentliches Löschen oder das Überschreiben kritischer Dateiversionen gehört zum Alltag der IT-Forensik. Oftmals ist dies kein Resultat von Nachlässigkeit, sondern von der zunehmenden Komplexität der Benutzeroberflächen. Wenn Mitarbeitende mit einer Flut von Benachrichtigungen und komplexen Verzeichnisstrukturen konfrontiert sind, sinkt die Fehlerschwelle.

- **Das Risiko der "Schatten-IT" durch Unwissenheit:** Ein zentrales Problem ist das mangelnde Bewusstsein für die Grenzen der offiziellen Backup-Strukturen. Mitarbeitende nutzen oft private Cloud-Speicher oder USB-Sticks, um "schneller" arbeiten zu können. Diese Daten entziehen sich der unternehmensweiten Sicherungsstrategie vollständig. Wenn ein Gerät defekt ist oder verloren geht, sind die darauf befindlichen Geschäftsdaten

unwiederbringlich verloren.

- **Fehlkonfigurationen durch Administratoren:** Menschliches Versagen ist nicht auf Endanwender beschränkt. Ein klassisches Szenario ist der "Copy-Paste-Fehler" eines Administrators bei der Konfiguration von Backup-Ausschlüssen. Wird versehentlich ein Verzeichnis ausgeschlossen, das zwar temporär wirkt, aber die primären Datenbankdateien enthält, bleibt das System scheinbar funktionsfähig, bis im Ernstfall die Wiederherstellung scheitert.

Erweitertes Beispiel: Ein Marketingmitarbeiter eines Schweizer Verlags arbeitet an einer grossangelegten Kampagne. Da das interne Netzlaufwerk aufgrund von Wartungsarbeiten kurzzeitig langsam reagiert, verschiebt er den gesamten Rohdaten-Ordner (ca. 500 GB Bildmaterial) auf seinen lokalen Desktop, um flüssiger arbeiten zu können. Er vergisst jedoch, die Daten nach Abschluss der Arbeit zurückzusichern. In der folgenden Nacht erleidet seine lokale Festplatte einen mechanischen Defekt. Da lokale Desktops gemäss der Unternehmensrichtlinie nicht gesichert werden, sind die Arbeitsstunden von drei Wochen und teure Zukäufe von Bildlizenzen verloren. Der Mitarbeiter war sich der Tatsache, dass sein Desktop eine "backupfreie Zone" ist, schlicht nicht bewusst.

4.2 Sabotage, Insider-Bedrohungen und Passworthygiene

Der "innere Feind" ist eines der am schwierigsten zu kalkulierenden Risiken. Mevluet Polat betont, dass Sabotageakte oft von Personen ausgehen, die bereits im Unternehmen etabliert sind und über legitime Zugriffsrechte verfügen.

- **Die Gefahr beim Offboarding:** Wenn ein Mitarbeiter das Unternehmen im Streit verlässt, beginnt eine kritische Phase. Wird der Zugang zu den Backup-Systemen nicht unmittelbar gesperrt, kann die Person mit ihrem Fachwissen gezielt die letzte funktionierende Sicherung löschen oder Skripte hinterlassen ("Logic Bombs"), die Daten zeitversetzt vernichten. Dies stellt nicht nur einen materiellen Schaden dar, sondern untergräbt auch das Vertrauen der Kunden und Partner massiv.
- **Passworthygiene und Social Engineering:** Schwache oder mehrfach verwendete Passwörter sind das Haupteinfallstor für Angriffe. Menschliche Psychologie wird hierbei gezielt durch "Social Engineering" ausgenutzt. Angreifer geben sich als IT-Support aus und bewegen Mitarbeitende dazu, ihre Zugangsdaten preiszugeben. Da Backups oft administrative Privilegien erfordern, ist ein kompromittiertes Admin-Passwort der "Generalschlüssel" zum digitalen Suizid des Unternehmens. Ohne Multi-Faktor-Authentifizierung (MFA) ist die Hürde für Angreifer gefährlich niedrig.

Präventionsmassnahme nach Polat: Die technische Lösung ist hier nur die halbe Miete. Viel wichtiger ist die Etablierung einer "Security Culture". Regelmässige, praxisnahe Schulungen müssen den Mitarbeitenden klarmachen, dass Datensicherheit kein Hindernis, sondern eine Voraussetzung für ihren Arbeitserhalt ist. Das "Principle of Least Privilege" muss strikt umgesetzt werden: Niemand sollte mehr Rechte haben, als für die tägliche Arbeit unbedingt

notwendig sind. Zudem sollten administrative Aufgaben im Backup-Bereich nach dem Vier-Augen-Prinzip kontrolliert werden, um sowohl Fehlbedienung als auch Sabotage zu erschweren.

5. Organisatorische Risiken: Strukturmängel als Gefahrenquelle

Selbst wenn die technische Infrastruktur redundant ausgelegt ist und die Mitarbeitenden geschult sind, kann das Gesamtsystem an tief verwurzelten organisatorischen Defiziten scheitern. Organisatorische Risiken sind oft unsichtbar, da sie sich in Prozessen, Hierarchien und fehlenden Definitionen verbergen. Sie stellen eine schleichende Gefahr dar, die erst in einer echten Krisensituation – wenn jede Sekunde zählt – voll zum Tragen kommt.

5.1 Fehlende Strategie, Dokumentation und Kennzahlendefinition

Eine fehlende oder veraltete Backup-Strategie gleicht einer Expedition in unwegsames Gelände ohne Karte und Kompass. Mevluet Polat hebt hervor, dass ohne eine fundierte Business Impact Analyse (BIA) keine zielgerichtete Sicherung möglich ist. Unternehmen müssen ihre Daten klassifizieren und für jede Klasse spezifische Kennzahlen definieren:

- **RPO (Recovery Point Objective):** Diese Kennzahl definiert den maximal tolerierbaren Datenverlust zwischen dem Zeitpunkt des Ausfalls und der letzten erfolgreichen Sicherung. Wird ein RPO von 24 Stunden gewählt, akzeptiert das Unternehmen den Verlust eines ganzen Arbeitstages. In Branchen wie dem Finanzsektor kann jedoch schon ein RPO von wenigen Minuten existenzbedrohend sein.
- **RTO (Recovery Time Objective):** Dies ist die Zeitspanne, die vergehen darf, bis ein System nach einem Ausfall wieder produktiv verfügbar ist. Ein kurzes RTO erfordert oft teure Hochverfügbarkeitslösungen, während ein langes RTO den Stillstand ganzer Produktionsstrassen bedeuten kann.

Das Risiko des Dokumentationsmangels: Ein wesentlicher Teil organisatorischer Risiken ist das Entstehen von Wissen-Silos. Oft existiert das gesamte Know-how über die komplexe Wiederherstellungsprozedur nur in den Köpfen weniger Spezialisten. Wenn im Ernstfall der verantwortliche Administrator nicht greifbar ist (Urlaub, Krankheit, Kündigung) und keine detaillierte, regelmässig aktualisierte Dokumentation vorliegt, verlängert sich die Ausfallzeit (RTO) unkontrollierbar. Eine Dokumentation muss so verfasst sein, dass eine qualifizierte Fachkraft die Wiederherstellung auch ohne Vorwissen über die spezifische Umgebung durchführen kann.

5.2 Testverfahren, Zuständigkeiten und Compliance-Druck

Ein Backup, das nie erfolgreich wiederhergestellt wurde, existiert de facto nicht. Mevluet Polat warnt vor der trügerischen Sicherheit durch automatisierte Bestätigungs-E-Mails. Das

Phänomen des "Silent Failure" – bei dem die Backup-Software zwar Erfolg meldet, die Daten aber aufgrund von Fehlern im Dateisystem oder Verschlüsselungsalgorithmus unbrauchbar sind – ist eine reale Bedrohung.

- **Regelmässige Restore-Tests:** Ohne einen festgeschriebenen Zeitplan für Wiederherstellungstests bleibt unklar, ob die vorhandenen Backups im Ernstfall tatsächlich funktionieren. Solche Tests sollten nicht nur einzelne Dateien, sondern vollständige Disaster-Recovery-Szenarien abdecken, einschliesslich der Rekonstruktion ganzer Serverumgebungen auf neuer Hardware oder in der Cloud.
- **Klare Zuständigkeiten (RACI-Matrix):** Organisatorische Fehler entstehen oft durch die Annahme, "jemand anderes" würde die Kontrolle übernehmen. Wer ist verantwortlich für die tägliche Prüfung? Wer autorisiert das Löschen alter Archivdaten? Unklare Rollen führen zu Vernachlässigung der Kontrollpflichten.
- **Compliance und nDSG:** In der Schweiz hat sich mit dem neuen Datenschutzgesetz (nDSG) der regulatorische Druck massiv erhöht. Unternehmen sind gesetzlich verpflichtet, angemessene technische und organisatorische Massnahmen (TOM) zum Schutz von Personendaten zu treffen. Ungenügende Archivierungsprozesse oder das Unvermögen, Daten gemäss dem "Recht auf Vergessenwerden" gezielt zu löschen (ohne die Integrität des Gesamtarchivs zu zerstören), können hohe Bussgelder und irreparable Reputationsschäden nach sich ziehen.

Erweitertes Beispiel: Ein Finanzdienstleister in der Genfersee-Region erlitt nach einem Ransomware-Angriff einen massiven Systemausfall. Zwar waren Backups der letzten sechs Monate vorhanden und die Software meldete jeden Morgen "Job successful". Doch bei der versuchten Wiederherstellung stellte sich heraus, dass die Backup-Software aufgrund eines fehlerhaften Updates seit Wochen nur noch die Verzeichnisstruktur, aber keine tatsächlichen Dateihalte mehr gesichert hatte. Da nie ein physischer Restore-Test durchgeführt wurde, fiel dieser systematische Fehler nicht auf. Die Folge war ein totaler Verlust der operativen Daten des letzten Quartals und eine Untersuchung durch die Finanzmarktaufsicht wegen mangelnder Compliance.

6. Externe Risiken: Die Bedrohungslage ausserhalb des Perimeters

Kein Unternehmen ist eine Insel. Mevluet Polat analysiert treffend, dass Bedrohungen nicht nur aus dem Inneren, sondern massiv von aussen auf die digitale Substanz einwirken. Diese Risiken entziehen sich oft der direkten Kontrolle und erfordern daher besonders robuste Abwehrmechanismen.

6.1 Cyberangriffe und Ransomware: Die gezielte Sabotage der Rettungsboote

Cyberkriminalität hat sich zu einer hochprofessionellen Industrie entwickelt. Moderne Ransomware-Attacken folgen oft einem perfiden Muster: Bevor die eigentliche Verschlüsselung der Produktionsdaten beginnt, verbringen Angreifer Tage oder Wochen im Netzwerk, um die Datensicherungssysteme zu identifizieren und zu korrumpieren. Das Ziel ist es, die "Rettungsboote" des Unternehmens zu zerstören, um die Wahrscheinlichkeit einer Lösegeldzahlung zu maximieren.

- **Das Konzept der Unveränderbarkeit (Immutability):** Um diesem Risiko zu begegnen, müssen Backups gegen nachträgliche Änderungen geschützt werden. "Object Lock"-Technologien verhindern, dass Daten innerhalb einer festgelegten Frist gelöscht oder verschlüsselt werden können – selbst mit Administrator-Rechten.
- **Der physische Air Gap:** Eine der effektivsten Methoden gegen Cyberangriffe ist die physische Trennung (Air Gap). Daten werden auf ein Medium geschrieben, das nach dem Vorgang physisch vom Netzwerk getrennt wird (z. B. LTO-Bänder, die in einem Tresor gelagert werden). Ein Hacker kann keine Daten löschen, zu denen keine elektronische Verbindung besteht.

6.2 Naturereignisse, Diebstahl und das Lieferantenrisiko (Cloud Concentration Risk)

Physische Risiken wie Brand, Hochwasser oder Erdbeben können ganze Rechenzentren und deren lokale Sicherungen vernichten. Mevluet Polat mahnt hier zur strikten Einhaltung der **3-2-1-Regel**: Mindestens **3** Kopien der Daten auf **2** verschiedenen Medientypen, wobei **1** Kopie an einem **externen** Standort aufbewahrt werden muss.

- **Die Illusion der Cloud-Sicherheit:** Viele Unternehmen migrieren ihre Backups in die Cloud und gehen fälschlicherweise davon aus, dass der Provider alle Risiken übernimmt. Dies ist ein gefährlicher Trugschluss. Im "Shared Responsibility Model" der meisten Cloud-Anbieter ist der Kunde allein für die Sicherung seiner Daten verantwortlich. Fällt der Provider aufgrund technischer Probleme, Insolvenz oder politischer Krisen aus, besteht kein Zugriff mehr auf die externen Backups.
- **Geografische Redundanz:** Es reicht nicht aus, das Backup in einem anderen Raum desselben Gebäudes zu lagern. Eine echte georedundante Sicherung muss in einer anderen Brandabschnitts- oder gar Erdbebenzone liegen, um bei grossflächigen Katastrophen verfügbar zu bleiben.
- **Physischer Diebstahl:** Der Diebstahl von unverschlüsselten Backup-Medien aus Büros oder Fahrzeugen ist ein massives Sicherheitsleck. Ohne durchgehende AES-Verschlüsselung sind archivierte Daten für Diebe sofort lesbar, was zu schweren Datenschutzverletzungen führt.

Zusammenfassende Implikation: Die Abhängigkeit von externen Dienstleistern (Cloud-Backup) muss durch klare Exit-Strategien und Multi-Cloud-Ansätze flankiert werden. Nur wer die Kontrolle über seine Verschlüsselungsschlüssel (Bring Your Own Key - BYOK) behält und

regelmässig prüft, ob die Daten auch ohne die proprietären Tools des Providers lesbar sind, minimiert das Lieferantenrisiko effektiv.

7. Risikoidentifikation und Prävention

Um den vielfältigen Gefahren der modernen IT-Umwelt wirksam zu begegnen, schlägt Mevluet Polat einen proaktiven, strukturierten Prozess vor. Prävention ist hierbei kein einmaliges Projekt, sondern ein kontinuierlicher Lebenszyklus, der tief in die Unternehmenskultur integriert werden muss. Ziel ist es, eine "Resilienz-Architektur" zu schaffen, die auch unter extremen Belastungen die geschäftskritischen Funktionen aufrechterhält.

7.1 Die systematische Risikoanalyse: Methodik und Schutzbedarf

Jedes Unternehmen muss individuell prüfen, welche Daten wie schützenswert sind. Eine fundierte Risikoanalyse nach Polat basiert auf der Identifikation der Assets und der Bewertung ihrer Kritikalität anhand der CIA-Triade (Confidentiality, Integrity, Availability):

- **Inventarisierung der Datenlandschaft:** Bevor Massnahmen getroffen werden können, muss bekannt sein, welche Daten wo gespeichert sind. Dies beinhaltet strukturierte Daten (Datenbanken) ebenso wie unstrukturierte Daten (E-Mails, Dokumente auf lokalen Desktops).
- **Bedrohungsmodellierung:** Hierbei werden potenzielle Bedrohungsszenarien (z. B. Ransomware, Brand, menschliches Versagen) gegen die vorhandenen Assets geprüft.
- **Bewertung von Eintrittswahrscheinlichkeit und Schadensausmass:** Die Ergebnisse werden oft in einer "Risk Map" visualisiert. Risiken im roten Bereich (hohe Wahrscheinlichkeit, hoher Schaden) erfordern sofortige Investitionen, während Risiken im grünen Bereich lediglich überwacht werden müssen.

7.2 Ganzheitliche Schutzmassnahmen und proaktives Monitoring

Ein effektives Sicherheitsniveau kann nur durch die Kombination verschiedener Massnahmentypen erreicht werden (Defense-in-Depth):

- **Präventive Massnahmen:** Hierzu zählen technische Barrieren wie Verschlüsselung, Firewalls und Zugangskontrollen, aber auch organisatorische Regelungen wie regelmässige Sicherheitsschulungen und klare Passwortrichtlinien.
- **Detektive Massnahmen (Monitoring):** Ein kontinuierliches Monitoring der Backup-Infrastruktur ist unerlässlich. Dies umfasst nicht nur die Prüfung der Erfolgsmeldungen, sondern auch die Überwachung der Datenwachstumsraten. Ein plötzlicher Anstieg der Datenmenge im Backup kann auf eine laufende Verschlüsselung durch Ransomware hindeuten. Moderne SIEM-Systeme (Security Information and Event Management) können solche Anomalien in Echtzeit melden.
- **Korrektive Massnahmen (Notfallplan):** Ein dokumentierter Notfallplan (Disaster Recovery Playbook) definiert präzise Abläufe für den Fall des Eintretens eines Schadensereignisses.

Der Notfallplan im Detail: Ein guter Plan ist mehr als eine Telefonliste. Er muss klare Rollendefinitionen enthalten (z. B. wer bildet den Krisenstab?), technische Wiederherstellungsanleitungen (Step-by-Step) bereitstellen und Kommunikationsstrategien für Kunden, Behörden und Medien festlegen. Regelmässige "Table-Top-Übungen", bei denen Krisenszenarien theoretisch durchgespielt werden, stellen sicher, dass die Verantwortlichen im Ernstfall besonnen handeln können.

8. Die Rolle der Geschäftsleitung: Verantwortlichkeit und Governance

Ein zentraler Pfeiler in der Argumentation von Mevluet Polat ist die strategische Verankerung der Datensicherheit auf höchster Managementebene. Die weit verbreitete Ansicht, Backup und Archivierung seien rein operative Aufgaben der IT-Abteilung, ist ein gefährlicher Irrtum. Da der Totalverlust von Daten die Existenz des Unternehmens unmittelbar gefährden kann, ist die Sicherstellung eines angemessenen Schutzniveaus eine unverzichtbare Komponente der Corporate Governance.

- **Gesetzliche Sorgfaltspflicht (Art. 716a OR):** In der Schweiz trägt der Verwaltungsrat die unübertragbare und unentziehbar Aufgabe der Oberleitung des Unternehmens sowie der Festlegung der Organisation. Ein Versäumnis bei der Sicherstellung der Datenverfügbarkeit kann als Verletzung dieser Sorgfaltspflicht gewertet werden, was im Falle eines Schadens zu einer persönlichen Haftung der Organe führen kann.
- **Bereitstellung von Ressourcen:** Die Geschäftsleitung ist dafür verantwortlich, dass ausreichend Budget und Personal für die Implementierung und den Betrieb moderner Sicherungssysteme zur Verfügung stehen. Sicherheit darf nicht als reiner Kostenblock betrachtet werden, sondern als notwendige Investition in die Betriebskontinuität.
- **Definition des Risikoappetits:** Die Führungsebene muss entscheiden, wie viel Risiko das Unternehmen bereit ist zu tragen. Dies äussert sich in der Festlegung der bereits erwähnten Kennzahlen RPO und RTO. Diese Entscheidungen sind geschäftskritisch und können nicht an die IT delegiert werden.
- **Etablierung des "Three Lines of Defense"-Modells:**
 1. *First Line:* Operative Einheiten und IT-Betrieb (Umsetzung der Backups).
 2. *Second Line:* Risk Management und Compliance (Überwachung der Richtlinien und Risikoanalysen).
 3. *Third Line:* Interne oder externe Revision (Unabhängige Prüfung der Wirksamkeit des gesamten Systems).

Indem die Geschäftsleitung diese Strukturen fördert und aktiv vorlebt ("Tone at the Top"), wandelt sich die Datensicherung von einer technischen Pflichtübung zu einem strategischen Wettbewerbsvorteil, der das Vertrauen von Kunden und Investoren nachhaltig stärkt.

9. Fazit und Ausblick

Zusammenfassend lässt sich festhalten, dass die Risiken der Datensicherung und Archivierung ein multidimensionales Problem darstellen. Wie Mevluet Polat präzise analysiert hat, reicht es nicht aus, sich auf die Technik zu verlassen. Nur durch das Zusammenspiel von moderner Hardware, geschultem Personal, klaren organisatorischen Strukturen und einer proaktiven Verteidigung gegen externe Bedrohungen kann die Datenintegrität gewahrt werden.

In der Zukunft wird die Bedeutung von künstlicher Intelligenz im Backup-Monitoring zunehmen, um Anomalien (wie z.B. physische oder menschliche Verhaltensmuster) in Echtzeit zu erkennen. Dennoch bleibt die menschliche Verantwortung und die strategische Planung das Fundament jeder sicheren Archivierung.

10. Diskussion der Beispiele

Die in diesem Artikel angeführten Beispiele verdeutlichen die theoretischen Risiken. Sie zeigen auf, dass oft banale Ursachen – ein fehlendes Kabel an der USV, eine falsche Annahme eines Mitarbeiters oder ein nicht durchgeführtes Update – zu katastrophalen Datenverlusten führen können. Die Komplexität, die Polat anspricht, äussert sich vor allem in der Verkettung dieser Umstände. Ein wirksames Risikomanagement muss daher "Murphy's Law" einplanen: Alles, was schiefgehen kann, wird schiefgehen. Eine robuste Datensicherung ist die einzige Versicherung gegen diesen Grundsatz.

11. Quellenverzeichnis

Im Folgenden werden die wesentlichen theoretischen Grundlagen und Referenzen aufgeführt, die für die Erstellung dieses Artikels und die Untermauerung der Thesen von Mevluet Polat herangezogen wurden:

1. **Polat, M. (2024):** *Risiken der Datensicherung und Archivierung*. Grundlagenwerk zur Risikoanalyse in betrieblichen IT-Infrastrukturen.
2. **Bundesamt für Cybersicherheit (BACS) Schweiz (2023):** *Leitfaden für die Datensicherung in KMU*. Empfehlungen zur Prävention von Datenverlust.
3. **ISO/IEC 27001 (2022):** *Information security, cybersecurity and privacy protection*. Internationaler Standard für Informationssicherheits-Managementsysteme.
4. **Schneider, H. & Weber, R. (2021):** *IT-Sicherheitsmanagement in der Praxis*. Hanser Verlag, München (Kapitel zu Disaster Recovery und Business Continuity).
5. **Swiss IT Magazine (2023):** *Backup-Strategien im Vergleich: Cloud vs. On-Premise*. Fachartikel zur technischen Umsetzung von Datensicherungen.
6. **Tannenbaum, A. S. & Wetherall, D. J. (2019):** *Computernetzwerke*. Pearson Studium (Grundlagen zur Netzwerkstabilität und Datenübertragung).
7. **Zuger, M. (2022):** *Rechtliche Aspekte der Datenarchivierung in der Schweiz*. Schulthess

Juristische Medien AG (Compliance und gesetzliche Aufbewahrungspflichten).

8. **BSI (Bundesamt für Sicherheit in der Informationstechnik) (2023): *IT-Grundschutz-Kompendium: Baustein CON.6: Löschen und Vernichten sowie OPS.1.1.5: Logging und Monitoring.***

Ende des Artikels